

FACULTY OF ACCOUNTING AND INFORMATICS
DEPARTMENT OF INFORMATION TECHNOLOGY

2023
YEAR END MAIN EXAMINATION

INSTRUCTIONAL PROGRAMME : BACHELOR OF INFORMATION & COMM. TECH

INSTRUCTIONAL OFFERING : INFORMATION ASSURANCE & SECURITY

PAPER NUMBER : 1

SUBJECT CODE/S : INAS201

DATE : 22 November 2023

DURATION : 3 HOURS

TIME : 14H00

TOTAL MARKS : 100

NUMBER OF PAGES : 6 (with cover page)

EXAMINER/S : FT Khan

MODERATOR/S : B Van Niekerk

INSTRUCTIONS/REQUIREMENTS:-

[1] Answer all questions

Do not turn the page until permission is given

QUESTION ONE

[22 MARKS]

1.1 Define each of the following in one short sentence. [8]

- 1.1.1 Shellcode
- 1.1.2 Buffer overflow
- 1.1.3 Principle of Least Privilege
- 1.1.4 Public key cryptosystem

1.2 Multiple choice questions. [6]

1.2.1 To counter threats to remote user authentication, systems generally rely on some form of _____ protocol.

- A. eavesdropping
- B. Trojan horse
- C. challenge-response
- D. denial-of-service

1.2.2 _____ is the granting of a right or permission to a system entity to access a system resource.

- A. Authorization
- B. Authentication
- C. Control
- D. Monitoring

1.2.3 _____ will integrate with the operating system of a host computer and monitor program behavior in real time for malicious actions.

- A. Fingerprint-based scanners
- B. Behavior-blocking software
- C. Generic decryption technology
- D. Heuristic scanners

1.2.4 Security concerns that result from the use of virtualized systems include _____.

- A. guest OS isolation
- B. guest OS monitoring by the hypervisor
- C. virtualized environment security
- D. all of the above

1.2.5 A _____ uses macro or scripting code, typically embedded in a document and triggered when the document is viewed or edited, to run and replicate itself into other such documents.

- A. boot sector infector
- B. file infector
- C. macro virus
- D. multipartite virus

1.2.6 The following steps should be used to secure an operating system:

- A. test the security of the basic operating system
- B. remove unnecessary services
- C. install and patch the operating system
- D. all of the above

1.3 The open design would seem to favour the attacker because it certainly opens the implementation and perhaps also the design for the attacker to study. Justify that open design overrides this seeming advantage and leads to solid security. [4]

1.4 You have forgotten your password, so you click on “forgot my password” to have a new password sent by email. Sometimes the site tells you what your password was; other times, it sends you a new (usually temporary) password. What are the privacy implications of each approach? [4]

QUESTION TWO

[30 MARKS]

2.1 Layered design ensures an operating system can protect itself as well as protect other objects.

2.1.1 Briefly explain the layered design. [3]

2.1.2 Briefly describe any two security benefits. [4]

2.2 **False positive** and **false negative** rates are often complementary. Lowering one raises the other. Explain **false positive** and **false negative** and state one situation in which false negatives are significantly more serious than false positives [4]

- 2.3 Describe how “Trojan” attacks can infect a computer and what vulnerabilities are necessary to enable them to happen. [3]
- 2.4 Answer the following questions in a few sentences each:
- 2.4.1 Why is an access control matrix rarely implemented as a matrix? Name and describe the two common ways in which access control matrices are implemented. [4]
- 2.4.2 On Android phones, applications ask the users to approve permissions at install time. Sometimes applications request more permissions than the application actually requires, e.g., access to location information for a news feed. Give two possible reasons why the developer might ask for unnecessary permissions. Which one of the Saltzer-Schroeder design principles is being violated by this practice? Explain. [3]
- 2.5 Let’s consider the following scenario:
Ann owns (O) File A and can read (R), write (W) and execute (X) this file. She can read and execute File C and can read File B. Bob owns File B and can read, write and execute this file. He can write File C, but cannot access A. Mary owns File C and she can read, write and execute this file but cannot access File A and B.
- 2.5.1 Draw an access control matrix for the above scenario. [6]
- 2.5.2 Write a set of capability lists for this situation. [3]

QUESTION THREE

[24 MARKS]

- 3.1 In general, there are three basic methods to implement authentication. List them and provide an example of each. [3]
- 3.2 Man-in-the-middle attack is one of the potential flaws in the design of the Wireless Protected Access (WPA) protocol.
- 3.2.1 Describe what man-in-the-middle attack is. [3]
- 3.2.2 Explain how a man-in-the-middle attack on a Wi-Fi network can be defeated. [3]
- 3.3 For each scenario, choose the most relevant security principle from the list and write a short description of it. Each option is used exactly once.
- 3.3.1 A bank installs alarms to alert the security guards in case intruders break in. [3]
- 3.3.2 To access top-secret Information Technology data, Senzo must enter a password that only he knows, and Nikyle must enter a second password that only he knows. [3]
- 3.3.3 In an airport, every passenger must pass through the security checkpoint. [3]
- 3.3.4 When debugging students' code, Visual Studio ran all code with administrator privileges. The latest version of Visual Studio runs untrusted code in an isolated environment (sandbox) instead. [3]
- 3.3.5 To prevent memory safety vulnerabilities, a programmer enables ASLR, non-executable pages, and stack canaries. [3]

Security Principles List

Defense in depth, Detect if you can't prevent, Separation of privilege, Consider human factors, Ensure complete mediation, Least privilege, Don't rely on security through obscurity, Design security from the start

QUESTION FOUR

[24 MARKS]

- 4.1 The public key for the RSA cryptosystem is a pair of numbers $(n; e)$ where $n=pq$, the product of two primes p and q . The secret key is $(n; d)$. Suppose we have $p = 5$, $q = 11$.
- 4.1.1 Calculate n and $\phi(n)$. [2]
- 4.1.2 For this cryptosystem e and d are identified as 3 and 27 respectively. Are the values for e and d valid? Motivate your answer by providing the equation for identifying e and d . [4]
- 4.2 Encrypt the text "MEET ME TONIGHT" using Caesar cipher with shift key = 9. [2]
- 4.3 Many attacks exploit a buffer overflow.
- 4.3.1 Using an example explain buffer overflow and how it can be exploited to cause a privilege escalation attack [6]
- 4.3.2 Identify and briefly describe any two mechanisms that can be implemented to control buffer overflow. [6]
- 4.4 An application program calls two methods **calcprice** and **writetotalprice** (price is a field in a database; **calcprice** calculates $\text{price} = \text{price} * \text{quantity}$; **writetotalprice** writes total price). Using this information :
- 4.4.1 Explain race conditions and the security problem that may occur. [4]

